Capítulo III. Resultados

Sistema integrado de eventos laborales (JML) · Andina Servicios S.A.S. (empresa ficticia, datos ficticios)
Politécnico Grancolombiano · Gerencia de Proyectos en Seguridad de la Información · Grupo D01
25 de octubre de 2026 · actualizado el 9 de noviembre de 2026

> **Nota para el equipo.** Las cifras de este capítulo salen de las evidencias de `docs/entregables/auditoria/` (cada una con su comando, salida, versión, *commit* y fecha). La comparación con «otros trabajos previos» usa lo que existe en el repositorio: el estado documentado del proyecto, la auditoría interna del 12/10/2026 y la Entrega 3 del 24/10/2026, además de los marcos de referencia publicados (OWASP, CIS). **No se inventaron citas bibliográficas.** Si su marco conceptual incluye trabajos académicos o de la industria, añádalos como filas de la tabla de la sección 3.2.4 con sus referencias. La sección 3.4 usa como problema y objetivos lo que dice el SRS; ajústela a sus capítulos I y II de planteamiento y objetivos.

3.1 Análisis de resultados: cada prueba definida y su resultado

Cada prueba que el plan y el SRS definen se relaciona con lo que midió y con su veredicto. «Meta» es el criterio del plan o del requisito.

3.1.1 Pruebas funcionales y de calidad del código

Prueba definida	Meta	Resultado	Veredicto
Suite automática sin integración (dominio, aplicación, contratos, escenarios, adaptadores, seguridad, Gherkin)	0 fallos	2 574 pasan, 2 omitidas con motivo, 1 `xfail` registrada	Cumple
Integración contra PostgreSQL 17	0 fallos	251 pasan, 18 omitidas (requieren el Supabase real)	Cumple
Contrato y flujos contra GLPI 11 real	30 de 30	30 de 30 (fallaban 2 al inicio: B-16 y B-17)	Cumple tras corregir
Recorrido por navegador (Playwright) por el WAF	4 de 4	4 de 4 la primera corrida; 3 de 4 las dos siguientes por un 429 del WAF	Parcial (B-36)
Estabilidad: 20 corridas consecutivas	< 1 % inestables, sin reintentos	20 de 20 sin fallos, 1 632 pruebas cada una	Cumple
Cobertura de ramas	dominio >= 95 %, aplicación >= 90 %	97,74 % y 94,83 %; siete módulos de seguridad al 100 %	Cumple
Mutación (¿las pruebas notan los cambios?)	>= 85 %	dominio 97,8 %, aplicación 92,7 %, seguridad 96,1 %	Cumple
Defectos sembrados	detectar los 6	6 de 6 detectados (SQL por f-string, sin `REVOKE`, sin disparador, sin rol, `.pdf` renombrado, segundo uso del TOTP)	Cumple
Escenarios Gherkin	cada amenaza T1–T21 y N-1..N-5 con escenario	26 de 26 con escenario; 13 características	Cumple
Anexo A: 18 hojas del Excel	cada fila contrastada	157 filas: 139 cumplen, 6 parciales, 2 no verificables en local, 10 no aplican (ADR-031), 0 fallan	Cumple (con salvedades)

3.1.2 Pruebas de seguridad

Prueba definida	Meta	Resultado	Veredicto
Matriz de autorización (22 rutas × 2 métodos × 10 roles)	0 celdas distintas de lo esperado	440 celdas, 0 distintas; 403 frente a 404 comprobado	Cumple (B-26 documentada)
IDOR, asignación masiva y CSRF	respuesta idéntica a un id inexistente	cumplido, con control positivo	Cumple
Análisis estático (`ruff` S, `bandit`, `mypy` estricto, `import-linter`)	0 sin triage	0 errores; 3 falsos positivos triados; 3 contratos cumplidos	Cumple
Dependencias (`pip-audit`)	0	0 tras B-15	Cumple
Secretos (`gitleaks`)	0 en el historial	0 en el historial; 0 en la entrega	Cumple
ZAP activo, tres posiciones	sin alertas confirmadas	0 FAIL en las tres; 1 alerta alta (confianza baja) reproducida y descartada	Cumple
sqlmap, nivel 3 por el WAF y nivel 5 directo	0 inyecciones	0 en 4 y en 8 objetivos, con `Host` y segundo orden	Cumple
Superficie de red (nmap)	solo el WAF publica	solo 80 y 443 de BunkerWeb salen del equipo	Cumple
TLS (`testssl.sh`)	TLS 1.2 o superior, sin vulnerabilidades	solo 1.2 y 1.3; 0 vulnerabilidades; 10 de 10 saludos en TLS 1.3	Cumple
Imágenes (Trivy con KEV y EPSS)	0 críticas sin exención	propia 0 críticas; 0 de 139 CVE en KEV; terceros con exención escrita	Cumple (B-31)
Docker Bench (CIS)	sin avisos	42 comprobaciones, 12 avisos	Parcial (B-33)
Bases de datos (roles, disparadores, RLS)	impuestos por el motor	15 pruebas por rol y paridad con el catálogo de Supabase	Cumple (B-23)
Tráfico (centinela del campo restringido)	0 tramas hacia GLPI	0 de 31 240	Cumple
Tráfico (tokens de GLPI)	no viajan en claro	382 en claro dentro de la red interna	**No cumple** (B-32)
WAF (`pruebas.sh`)	200 en tráfico normal, 403 en ataques	cumplido en `app.*` y `glpi.*`; una exclusión puntual (regla 953100 en `/front/locale.php` de GLPI, B-39) con su prueba	Cumple
Reportería (CA-21)	ataque clasificado en < 2 min	en el mismo segundo	Cumple

3.1.3 Pruebas de disponibilidad y rendimiento

Prueba definida	Meta	Resultado	Veredicto
Detección de GLPI caído (RNF-01)	< 120 s	63 s	Cumple
Detección de la base caída	< 120 s	43 s	Cumple
Restauración (RTO)	<= 4 h	19 s, con la misma cabeza de la cadena de auditoría	Cumple
Rendimiento (RNF-06): 300 colaboradores, 20 usuarios	p95 < 800 ms por página, dashboard < 2 s	p95 de 466 a 649 ms; dashboard 786 ms	Cumple a 20 vueltas
Accesibilidad (RI-01)	WCAG 2.1 AA en contraste	texto >= 6,09:1; componentes >= 3:1 tras B-34	Cumple (sin evaluación manual)

3.1.4 Lectura de los resultados

1. **No hay hallazgos Críticos ni Altos.** De los 39, 15 son Medios, 18 Bajos y 6 Informativos. Los Medios abiertos más relevantes son el proceso único de `gunicorn` (B-06), la política de contraseña de Supabase (B-10), los tokens de GLPI en claro dentro de la red interna (B-32) y las vulnerabilidades de las imágenes de terceros (B-31).
2. **La exposición ponderada es pequeña.** El *score* global es 1,2 de 100 (la escala llama «aceptable» a 0 a 20), con **147 controles de ASVS verificados**. El número solo tiene sentido junto a esa cifra.
3. **La mayor parte del valor de la auditoría vino de medir, no de leer.** Seis hallazgos se encontraron al medir algo que el proyecto daba por cumplido: la API de GLPI con reloj fijo (B-17), el contraste de los campos (B-34), el perfil de la cuenta de servicio (B-35), el limitador de ritmo (B-36), el endurecimiento de contenedores (B-33) y las denegaciones sin rastro (B-25).
4. **Una falla de método se detectó a tiempo.** La primera medición de rendimiento (10 vueltas) dio 6 de 9 páginas sobre 800 ms; con las 20 vueltas de la medición original cumple, tres veces seguidas. Se conservó la corrida que no cumple como evidencia.

3.1.5 Pruebas de ataque dirigidas: hombre en el medio e inyección SQL (09/11/2026)

Esta ronda corresponde a la **fase de evidencias y auditoría** del cronograma del capítulo II (la fase que produce las cifras de seguridad con evidencia reproducible), y repite sobre el *stack* actual los dos ataques que la actividad del curso pide demostrar para las propiedades de confidencialidad, autenticidad e integridad. El detalle está en el Entregable 5 de Desarrollo Seguro (`docs/Desarrollo Seguro/5-Pruebas-de-ataque-MitM-y-SQLi.md`).

Prueba definida	Meta	Resultado	Veredicto
Inyección SQL, sqlmap nivel 5 (8 objetivos, `Host`, segundo orden)	0 inyectables	0 en 7 objetivos con veredicto; el de segundo orden heredó el 0 de `F6-04` (cortado por tiempo aquí)	Cumple
Inyección SQL, cargas manuales por el WAF	bloqueadas	5 de 5 con 403 (OWASP CRS)	Cumple
Inyección SQL, cargas manuales al ORM	tratadas como dato	200 sin error de base de datos; 404 por validación de longitud; 26 tablas intactas	Cumple
MitM: interceptor con certificado falso	rechazado por un cliente que valida	rechazado (error de certificado); solo un cliente comprometido (`-k`) lo acepta	Cumple
MitM: degradación de TLS	rechazada	`TLS 1.1` rechazado; el borde solo ofrece 1.2 y 1.3	Cumple
MitM: despojo de TLS	redirección + HSTS	puerto 80 -> 301; HSTS de un año	Cumple
MitM: robo de la cookie de sesión	Secure + HttpOnly + SameSite	los tres atributos presentes	Cumple
MitM: captura del tramo externo	credencial no en claro	0 apariciones de la contraseña centinela (va en TLS)	Cumple

Análisis por prueba. La integridad frente a la inyección se sostiene en dos capas independientes: el cortafuegos detiene las cargas evidentes (403) y, aun sin él, el ORM parametrizado de Django trata la carga como un dato literal, de modo que ningún `DROP TABLE` ni `UNION` tiene efecto. La autenticidad y la confidencialidad frente al hombre en el medio se sostienen en la validación del certificado por el cliente, en que no se puede degradar ni despojar el cifrado y en que la credencial viaja dentro de TLS. La única debilidad es de cifrado **interno** entre contenedores (B-30, B-32), aceptada y mitigada por el aislamiento de red.

Comparación con trabajos previos. Frente al Entregable 2 (25/10/2026), que ya había medido 0 inyecciones con sqlmap y un TLS sólido con testssl, esta ronda **añade la demostración activa del hombre en el medio** (certificado falso rechazado, anti-*downgrade*, anti-*strip*, captura del tramo externo), que antes solo estaba implícita en el inventario de TLS. El resultado de inyección coincide con el previo (0 inyectables), lo que confirma la postura entre dos estados del sistema separados por dos semanas y por los cambios de las sesiones recientes (CRUD de usuarios, consulta de tickets).

3.2 Comparación con otros trabajos previos

3.2.1 Contra lo que el proyecto documentaba

Afirmación documentada	Medido	Lectura
1 600 pruebas	1 618 en la línea base; 2 574 al final	Cierta; creció con las pruebas nuevas
Cobertura de ramas «99 %»	97,74 % (dominio) y 94,83 % (aplicación) en ramas puras	Era la métrica combinada con líneas, no de ramas
Mutación del dominio 93,6 %	97,8 %	Mejor
Rendimiento: dashboard 791 ms	786 ms	Reproducida
Detección de GLPI 63 s; de la base 56 s	63 s; 43 s	Reproducida; la base mejor
Restauración 23 s	19 s	Reproducida
CA-12 «cumplido»	el documento lo declaraba con un marcador sin reemplazar	Falsa (B-02); el verificador de la entrega ya lo impide

3.2.2 Contra la auditoría interna del 12/10/2026

Aspecto	Auditoría del 12/10	Esta auditoría
Hallazgos	12 (1 Alta, 5 Medias, 4 Bajas, 2 Informativas), todos corregidos	39 (0 Altas, 15 Medios, 18 Bajos, 6 Informativos)
La Alta	La API REST de GLPI respondía desde internet a través del WAF	No reaparece: el WAF sigue bloqueándola y se probó
Método	Lectura del código y pruebas manuales	Plan escrito, evidencia reproducible, control positivo y neutralización
Puntaje	Severidad	DREAD, factor de posición y score global
Cobertura de la propia suite	no medida	mutación de tres objetivos

3.2.3 Contra la Entrega 3 del 24/10/2026

Prueba	Entrega 3	Esta auditoría
Suite	1 581 pruebas	2 574, con las nuevas
Casos de uso por el WAF	34 pasos	matriz de 440 celdas y recorrido por navegador
ZAP	*baseline* con y sin WAF y un activo sin WAF (0 FAIL, 110 PASS)	activo autenticado en tres posiciones (0 FAIL; 137 a 142 PASS)
sqlmap	nivel 3	nivel 3 por el WAF y nivel 5 directo, con `Host` y segundo orden
Trivy	5 imágenes	5 imágenes con KEV y EPSS, reescaneadas tras reconstruir la propia
Tráfico	tokens de GLPI en claro, severidad Baja (C-01)	382 tokens, Media (B-32), con DREAD y posición del atacante
Consultas a la base	«valores ligados»	enlace del lado del cliente: el valor viaja dentro del texto SQL
Docker Bench	105 chequeos con avisos del anfitrión	42 comprobaciones de contenedores, 12 avisos (B-33)
Control positivo del escáner	no	sí
Neutralización y restauración	parcial	en cada corrida
Excel del Anexo A	no	157 filas contrastadas

Coincidencias: la misma postura general (sin inyecciones, sin servicios expuestos más allá del WAF, TLS sólido, inmutabilidad impuesta por el motor). **Diferencias:** más profundidad (activo en vez de *baseline*), una severidad más alta para lo mismo (con método), y hallazgos que la versión anterior no podía ver (B-33 a B-36).

3.2.4 Contra los marcos de referencia

Referente	Cómo se usó	Resultado
OWASP ASVS 5.0 (niveles 1 y 2, CSV oficial)	253 requisitos clasificados	147 verificados (74,6 % de los 197 aplicables), 36 parciales, 14 pendientes, 56 no aplican
OWASP Top 10:2025	cada hallazgo se asigna a su categoría	Control de acceso: B-26, B-35 · Configuración: B-33 · Diseño inseguro: B-09, B-36 · Componentes vulnerables: B-15, B-18, B-31 · Registro y alertas: B-21, B-25
CIS Docker Benchmark	Docker Bench sobre imágenes y contenedores	12 avisos de 42
WCAG 2.1 AA	contraste y estructura de las páginas	cumple lo mecánico; falta evaluación manual
CISA KEV y EPSS	priorizar vulnerabilidades de imágenes	0 de 139 CVE en KEV

El repositorio no contiene referencias a trabajos académicos externos, así que esta comparación se limita a los marcos de la tabla; los trabajos de su marco conceptual se agregan como filas con su referencia.

3.3 Indicadores tangibles y verificables por resultado esperado

Cada resultado esperado se mide con un indicador, una meta y una evidencia que cualquiera puede reproducir con el comando de su carpeta.

Resultado esperado	Indicador	Meta	Medido	Evidencia
Las reglas de negocio funcionan	Pruebas automáticas que pasan	0 fallos	2 574 de 2 574	`funcionales/ANEXO-A-JUNIT`

Resultado esperado	Indicador	Meta	Medido	Evidencia
Las pruebas protegen las reglas	Mutantes muertos en dominio, aplicación y seguridad	>= 85 %	97,8 · 92,7 · 96,1 %	`funcionales/F8-02-MUTACION-*`
El código está cubierto	Cobertura de ramas dominio y aplicación	>= 95 y >= 90 %	97,74 y 94,83 %	`funcionales/F9-COBERTURA-FINAL`
No hay solicitudes duplicadas	Conexiones concurrentes que registran la misma solicitud	exactamente 1	1	`funcionales/F1-02-INTEGRACION`
El campo restringido no sale	Tramas con el centinela hacia GLPI	0	0 de 31 240	`trafico/F7-04-CAPTURA-TRAFICO`
La auditoría no se altera	Cadena válida tras restaurar y tras la carga	válida	válida (secuencia 414; 603 y 6 586 registros)	`disponibilidad/F7-05-RESPALDO-Y-RESTAURACION`
Cada rol ve lo que debe	Celdas de autorización distintas de lo esperado	0	0 de 440	`autorizacion/matriz-authz.csv`
No hay inyección SQL	Parámetros inyectables	0	0 en 8 objetivos (nivel 5)	`vulnerabilidades/F6-04-SQLMAP-NIVEL5`
No hay inyección SQL (stack actual)	Parámetros inyectables	0	0 en 7 de 8 objetivos; cargas manuales bloqueadas o literales	`vulnerabilidades/DS5-SQLI-NIVEL5`, `DS5-SQLI-MANUAL`
El interceptor es detectado	Cliente que valida que acepta un certificado falso	0	0 (rechazado); solo `-k` lo acepta	`vulnerabilidades/DS5-MITM-INTERCEPTACION`
No se puede degradar ni despojar el cifrado	TLS < 1.2 aceptado / puerto 80 sin redirección	0 / 0	0 / 0; HSTS de un año	`vulnerabilidades/DS5-MITM-INTERCEPTACION`
La credencial no viaja en claro (tramo externo)	Apariciones de la contraseña en el tramo navegador<->WAF	0	0	`vulnerabilidades/DS5-MITM-INTERCEPTACION`
La aplicación resiste al escáner activo	Alertas FAIL de ZAP	0	0 en tres posiciones	`vulnerabilidades/F6-09-ZAP-DIRECTO`
El tráfico externo va cifrado	Saludos TLS 1.3 / vulnerabilidades de TLS	10 de 10 / 0	10 de 10 / 0	`trafico/ENTREGA3-CAPTURA-WEB-Y-POSTGRES`
Los secretos internos no viajan en claro	Peticiones con `App-Token` legible entre el worker y GLPI	0	382 (**no cumple**, B-32)	`trafico/F7-04-CAPTURA-TRAFICO`
Las dependencias son seguras	CVE explotadas (KEV) / críticas propias	0 / 0	0 de 139 / 0	`vulnerabilidades/F9-TRIVY-IMAGENES-REESCANEO`
El sistema responde	p95 por página / dashboard	< 800 ms / < 2 s	466 a 649 ms / 786 ms	`disponibilidad/F9-05-RENDIMIENTO-20V`
Las caídas se detectan	Segundos hasta detectar GLPI y la base	< 120	63 y 43	`disponibilidad/F7-08-DETECCION-*`
Se recupera de un desastre	Segundos de restauración	<= 14 400	19	`disponibilidad/F7-05-RESPALDO-Y-RESTAURACION`
Los ataques se ven	Segundos hasta ver un ataque clasificado	< 120	0	`disponibilidad/CA-21-REPORTERIA-WAF`
Se cumple el documento de tablas	Filas del Excel que cumplen / fallan	todas las aplicables / 0	139 de 147 aplicables / 0	`anexos/anexo-a-matriz.csv`
El riesgo residual es bajo	Hallazgos Críticos o Altos / *score* global	0 / <= 20	0 / 1,2	`anexos/score-global.md`
La entrega es íntegra	Hashes que cuadran / secretos	todos / 0	todos / 0	`manifiesto.sha256`, `gitleaks`

3.4 Coherencia entre planteamiento, marco, objetivos, metodología, cronograma y resultados

El problema que el SRS plantea es que, en la pyme ficticia, **las solicitudes de acceso por ingreso, traslado y retiro viajaban por correos y mensajes informales entre RRHH y TI**, sin un registro único ni separación de funciones y con el riesgo de que un acceso siguiera activo después de un retiro. El sistema responde con un flujo único (Solicitud -> Tickets por cola -> Resolución -> Estado de las cuentas), con seguridad por diseño.

Eslabón	Qué dice	Cómo se conecta con el siguiente
Problema	Accesos gestionados de forma informal; riesgo de cuentas activas tras un retiro	Pide un flujo formal, auditable y con segregación de funciones
Marco conceptual	Modelo *Joiner–Mover–Leaver*, STRIDE, DREAD, OWASP ASVS y Top 10, CIS, arquitectura hexagonal	Da el vocabulario y los criterios de aceptación
Objetivos	Los diez puntos del alcance del SRS	Cada uno tiene una prueba o una medición (tabla 2.3)
Metodología	Construir primero el núcleo, integrar con contratos, auditar en diez fases con evidencia reproducible	Produce las cifras de este capítulo
Cronograma	05/10 al 25/10/2026 (Gantt del capítulo II)	El orden núcleo -> adaptadores -> integración -> evidencias -> auditoría explica por qué cada medición pudo hacerse
Resultados esperados	Sin duplicados, auditoría inalterable, campos restringidos protegidos, rastro de cuentas, sistema responsivo	Los indicadores de la tabla 3.3
Resultados obtenidos	17 de 19 indicadores cumplen (no cumplen los tokens en claro y la meta de que todas las filas aplicables del Excel cumplan: 139 de 147); el *score* global es 1,2; sin hallazgos Críticos ni Altos	Cierran el ciclo y dejan los pendientes explícitos (3.5)

Verificaciones de coherencia hechas: (1) cada objetivo tiene un resultado y una evidencia; (2) cada resultado esperado tiene un indicador con meta; (3) cada indicador cita su evidencia; (4) la secuencia del cronograma es la que el método exige, sin pruebas antes de que exista lo que prueban; (5) los resultados que **no** cumplen se reportan, no se omiten.

Una incoherencia que se encontró y se corrigió: el documento de evidencias declaraba cumplido un criterio de aceptación (CA-12) con un marcador sin reemplazar (B-02). El verificador de la entrega ahora falla ante cualquier marcador y ante cualquier criterio «cumple» sin archivo de evidencia, y su prueba rechazó dos rutas mal escritas durante la misma redacción de la entrega.

Actualización del 09/11/2026. Las pruebas de ataque dirigidas (MitM e inyección SQL) mantienen la cadena de coherencia: atacan las propiedades de confidencialidad, autenticidad e integridad del **planteamiento**, con el vocabulario del **marco** (STRIDE, OWASP), sobre los objetivos de seguridad, con la **metodología** de evidencia reproducible y control positivo, en la **fase de evidencias** del cronograma, y con **indicadores** verificables (tabla 3.3). El resultado obtenido (0 inyectables, interceptación detectada) confirma los resultados esperados sin abrir hallazgos nuevos.

3.5 Limitaciones y trabajo pendiente

Limitación	Efecto en los resultados	Qué falta
El sistema depende de un solo equipo (ADR-031)	Sin almacenamiento inmutable; la disponibilidad depende de la máquina local	Programar la copia diaria, ya verificada contra una carpeta que simula el disco, en el equipo de operación
Supabase solo en lectura de catálogo	El servicio real de autenticación no se ejercitó	Una corrida autorizada contra el proyecto de Auth
Sin evaluación de accesibilidad con lector de pantalla	RI-01 parcial	Una evaluación manual
La clasificación de ASVS la hizo una sola persona	147 verificados sin revisión cruzada	Revisión del 10 % por una segunda persona
La CI de GitHub no corrió sobre estos cambios	G1b y G4 parciales; el `master` remoto conserva un fallo ya corregido en la rama	`git push` y una primera corrida del flujo nocturno
Cobertura de la superficie de ZAP en 90,9 %	Por debajo del 95 % del plan	Dos rutas inalcanzables con una sesión inyectada
Tres decisiones del equipo	B-06, B-26 y las propuestas de ADR siguen abiertas (B-36 se resolvió con ADR-032)	Aceptarlas o rechazarlas con un ADR

3.6 Conclusiones

1. **El sistema cumple lo que prometió y lo demuestra.** Los diez puntos del alcance tienen una prueba que pasa; los 21 criterios de aceptación cumplen.
2. **La seguridad se midió, no se supuso.** Sin inyecciones, sin servicios expuestos más allá del WAF, con la cadena de auditoría íntegra tras una restauración y 0 centinelas hacia GLPI en 31 240 tramas. La exposición ponderada es 1,2 de 100.
3. **Las debilidades reales son de operación y de decisión, no de código.** Lo más importante que queda es que la red entre el worker y GLPI no protege los tokens (B-32), que el proceso único de `gunicorn` pierde los desafíos del segundo factor al reiniciarse (B-06) y que la política de contraseña de Supabase depende de una acción humana (B-10).
4. **El método sirvió.** El control positivo evitó creerle a escáneres ciegos; los defectos sembrados mostraron que la suite detecta lo que debe; la mutación pasó de 77,8 a 92,7 % al revisar qué no se estaba comprobando; y el verificador de la entrega atrapó errores de la propia redacción.
5. **Lo que no se pudo medir está dicho.** La copia contra el disco externo real, el servicio real de Supabase Auth, la accesibilidad con lector de pantalla y la ejecución de la CI en GitHub quedan como trabajo explícito, con su guion.